
Portfolio CMS - เอกสารส่งมอบและหลักฐานตรวจสอบ

วันที่ตรวจ: 29 สิงหาคม 2026 (Asia/Bangkok) Branch: **feat/cms-repository** Commit ล่าสุดของ implementation/hardening: **bccbe43**
Commit ที่ใช้สำหรับหลักฐาน CI/Preview: **bccbe43**
Pull Request: #15

สรุปสำหรับผู้รับช่วงต่อ

โค้ด CMS สำหรับ Issue #1 และ Issue #2-#14 ถูกทำไว้ใน branch ข้างต้นแล้ว โดยคง Frontend และเนื้อหาเดิมเป็น baseline และเพิ่ม Content Repository แบบ static/database, Draft/Preview/Publish, revision history, archive/restore, slug redirects, managed media, Markdown policy, SEO และ operational guards

สถานะ release ที่ตรวจสอบได้ตอนนี้คือ โค้ดพร้อมและ CI/Preview build ผ่าน แต่ยังไม่ควรประกาศ Production cutover เพราะยังไม่มีหลักฐานจาก Supabase จริงและยังไม่สามารถเข้าสู่ Vercel protected Preview จาก session นี้ได้ จึงยังไม่ได้รัน migration/import/backup/restore หรือ mutation UAT บนระบบจริง

ห้ามตีความ HTTP 200 ของ <https://napatdev.com/> เป็นหลักฐานว่า CMS Production พร้อมใช้งาน เนื่องจากยังไม่มี การตรวจ environment, schema, data import และ publish flow บน Production แบบ authenticated

ภาพรวมสถาปัตยกรรม

Admin UI -> Better Auth/session -> Admin API -> atomic Content Service -> Prisma / portfolio_cms_*

||

| +-> Revision / Audit / Redirects

+-> Supabase Storage / portfolio-cms

Published Revision -> ContentRepository -> Public pages -> Metadata / JSON-LD / Sitemap / Search

Draft Revision ----> Exact Preview only (signed, short-lived token; no public indexing)

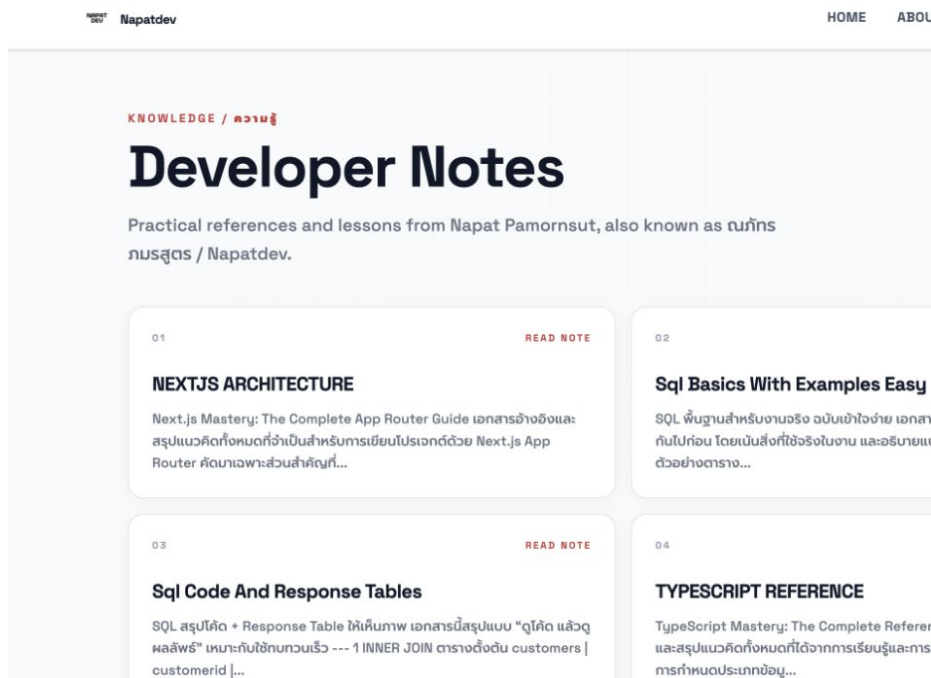
สถานะ Ticket

Issue	สิ่งที่ส่งมอบ	สถานะหลักฐาน
#1	โครง CMS และแผนส่งมอบ	โค้ดใน PR #15; รอ external UAT/cutover
#2-#4	Static ContentRepository สำหรับ Profile/Projects/Notes	local tests ผ่าน
#5	Prisma schema, database adapter และ importer	Prisma/CI ผ่าน; ยังไม่รันกับ Supabase จริง
#6	Admin auth, CSRF, Profile Draft/Preview/Publish	code/test พร้อม; authenticated browser UAT ยังรอ
#7-#8	Project lifecycle, slug conflict, managed media/Storage	code/test พร้อม; Storage จริงยังรอ
#9	Note Markdown, sanitize policy, SEO fields	policy tests ผ่าน; mutation UAT ยังรอ
#10	immutable revisions, restore-as-new-draft, archive, redirect chain	service tests ผ่าน
#11	verification scripts และ Playwright smoke	public local smoke ผ่าน; credential flow ยัง skipped
#12	schema allowlist, inventory, backup/restore และ guarded Storage setup	scripts พร้อม; target evidence ยังรอ
#13	Vercel Preview config และ CI gate	Preview deployment ผ่าน แต่ protected SSO
#14	Production/rollback runbook	ยังไม่ cutover; ต้องทำตาม checklist ด้านล่าง

หลักฐานที่รันแล้ว

- **npm test -- --run: 12 files, 41 tests passed**
- **npm run typecheck: ผ่าน (tsc --noEmit)**
- **npm run lint: 0 errors, 31 warnings;** warnings เป็น debt เดิมใน AI/notes และ unused constructor parameter ไม่ใช่ failure
- **npm run build: ผ่าน;** Next.js สร้าง admin, API, preview, public dynamic routes และ sitemap ได้
- **npx playwright test: 1 public test passed, 1 mutation test skipped;** public test ครอบคลุม list/detail, metadata, JSON-LD, search และ sitemap เพราะไม่มี **CMS_E2E_ADMIN_EMAIL, CMS_E2E_ADMIN_PASSWORD** และ **CMS_E2E_ALLOW_MUTATIONS=true**
- GitHub Actions Quality Gates ของ commit **bccbe43: ผ่าน (run 33263349417, job 99128945554)** รวม **npm ci, Prisma generate/validate, tests, typecheck, lint, build** และ public Playwright smoke
- Vercel Preview deployment ของ commit **bccbe43: ผ่าน (5LNJZTcdUkLgQSkdhVs8yMMLz);** deployment protection แสดงหน้า Vercel SSO ก่อนถึงแอป
- Worktree หลัง push: clean และ branch ตรงกับ **origin/feat/cms-repository**

ภาพ browser local ที่ตรวจ public Notes อยู่ใน:

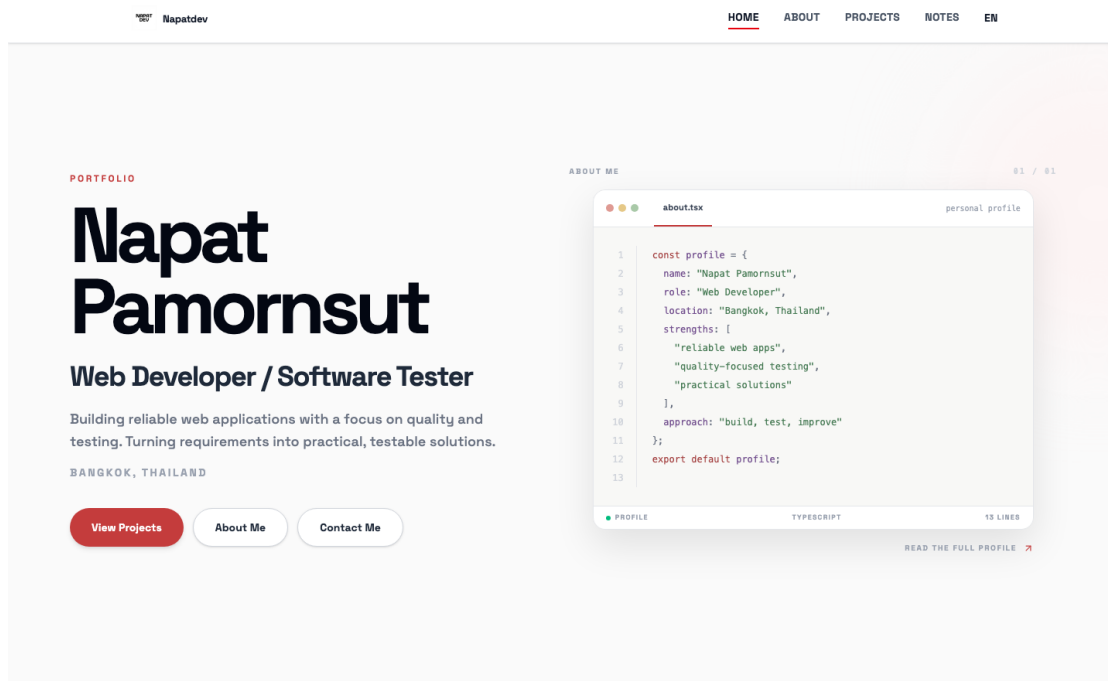


ภาพ browser local: public Notes viewport

Environment matrix

Target	VERCEL_ENV	Schema	Content source	หลักฐานปัจจุบัน	Gate ก่อน promote
Development	local/development	portfolio_cms_dev	static baseline หรือ database เมื่อกำหนดค่า	local tests/typecheck/lint/build/public smoke ผ่าน	ไม่ promote จาก local อย่างเดียว
Preview	preview	portfolio_cms_preview	database	Vercel deployment ผ่าน แต่ protected SSO	inventory, backup, migration, import, restore และ authenticated UAT
Production	production	portfolio_cms_prod	database	public root HTTP 200 แต่ /admin/login และ auth endpoint ยัง HTTP 404	backup ใหม่, migration/import, rollback check และ Production browser smoke

ภาพ public Production ปัจจุบันเป็นหลักฐานก่อน CMS cutover เท่านั้น ไม่มี session หรือข้อมูล admin:



ภาพ browser local: public Notes viewport

สิ่งที่เปลี่ยนในโค้ด

Content และ lifecycle

- **src/content/schema.ts** และ **src/content/input-schema.ts** เป็น typed Zod contracts สำหรับ localized EN/TH content, Profile, Project, Note, Skills, SEO และ media
- **src/content/repository.ts** กำหนด public contract; **static-adapter.ts** รักษา static baseline; **database-adapter.ts** อ่านเฉพาะ **PUBLISHED** revision ที่เลือกไว้
- **src/content/admin-service.ts** ทำ transaction เดียวสำหรับ save draft, publish, restore, archive, audit และ slug conflict
- Publish archive revision เดิมก่อนเปลี่ยน Published pointer; Archive mark Published และ pending Draft history เป็น Archived แต่เก็บ history ไว้สำหรับ Restore as Draft
- Restore สร้าง revision ใหม่เป็น Draft และไม่แก้ revision เก่า
- Managed media reference ต้องมี asset id/storage key/public URL ที่ตรงกันและอยู่ใต้ **projects/{documentId}/**; legacy source image URL ที่ไม่มี managed asset ยังถูกรักษาไว้ได้
- Public/admin URL guards ปฏิเสธ protocol-relative URL (**//host**) เพื่อไม่ให้หลุดออกนอก site origin
- Runtime Storage config ปฏิเสธ bucket ที่ไม่ใช่ dedicated **portfolio-cms** และ map configuration error เป็น **STORAGE_UNAVAILABLE** HTTP 502
- Database adapter ปฏิเสธ selected revision ที่สถานะจริงไม่ใช่ **PUBLISHED** เพื่อไม่ให้ Draft/Archived payload หลุดสู่ public read
- Public adapter ไม่คืน Draft/Archived; redirect query ตรวจสอบว่า document ต้นทางยัง Published และเดิน chain ได้ไม่เกิน 10 ชั้น
- Runtime database guard บังคับ **portfolio_cms_dev**, **portfolio_cms_preview** หรือ **portfolio_cms_prod** ให้ตรงกับ runtime และ **DATABASE_URL**; production runtime ไม่ fallback เป็น static โดยเจียบ
- Production runtime ปฏิเสธ **CONTENT_STORAGE** ที่ไม่ใช่ **database** เพื่อ fail closed เมื่อมีการตั้งค่า env ผิด

Admin และความปลอดภัย

- Better Auth อยู่ใน **src/server/auth.ts** พร้อม secure cookie ใน production, minimum password 12 ตัว, database rate limit และ sign-up disabled เป็นค่าเริ่มต้น; production ต้องมี **BETTER_AUTH_URL** แบบ HTTPS และไม่ใช่ localhost fallback
- **src/server/auth-guard.ts** ตรวจสอบ session และ **User.role=admin**
- mutation API ตรวจสอบ same-origin ใน **src/server/csrf.ts**
- Preview ใช้ HMAC token อายุ 15 นาทีใน **src/server/preview-token.ts** และอ่าน revision ที่ระบุแบบ exact เท่านั้น; production บังคับ **PREVIEW_SIGNING_SECRET** แยกจาก auth secret
- Activation เป็น one-time token route; ไม่แสดง token หรือ secret ใน response/log
- Sign out เป็น same-origin client action และพาลกลับ **/admin/login** หลังลบ session สำเร็จ
- Archive และ media delete ต้องส่ง explicit confirmation ที่ server ตรวจสอบ ไม่พึงเฉพาะ **window.confirm**
- Validation details จาก Zod ถูกส่งและแสดงต่อใน editor เพื่อให้แก้ field ที่ผิดได้โดยไม่สูญเสีย form state

Media และ Markdown

- Upload รับเฉพาะ PNG/JPEG/WebP ไม่เกิน 10 MB และตรวจสอบ magic bytes ก่อนส่ง Supabase Storage
- bucket/path ใช้ dedicated **portfolio-cms** และ **projects/{projectId}/{uuid}.{ext}**
- **scripts/ensure-storage.mjs** และ runtime storage layer ตรวจสอบหรือสร้างเฉพาะ bucket นี้ด้วย confirmation/allow-list ที่กำหนด; ไม่แตะ bucket อื่น
- **scripts/import-content.mjs**, **scripts/backup-portfolio.mjs** และ **scripts/restore-portfolio.mjs** ตรวจสอบ **current_database()/current_schema()** ก่อนทำงานที่อาจแตะข้อมูลหรือ restore
- migration/backup/restore ใช้ exact schema token matching ใน **search_path** ไม่ยอมรับชื่อ schema ที่เป็นเพียง substring
- ลบ media ไม่ได้ถ้ามี Published/Draft reference
- Storage upload/delete configuration และ network failure ถูกแปลงเป็น **STORAGE_UNAVAILABLE** HTTP 502 แทนการรายงานเป็น server error กว้าง ๆ
- **src/content/markdown-policy.ts** ปฏิเสธ executable HTML, event handler และ **javascript:**, **vbscript:**, **data:** URL; code fence ยังเขียนตัวอย่าง HTML ได้
- Public Note renderer ไม่ใช่ **rehypeRaw**

SEO และ derived consumers

การ Publish revalidate หน้า public, JSON-LD, sitemap และ search index ที่เกี่ยวข้อง รวมถึง project/note slug เดิมและใหม่เมื่อมีการ rename SEO override จาก Published Profile/Project/Note ถูกส่งต่อไปยัง metadata และ JSON-LD เดียวกับ content revision นั้น Metadata ของ Notes index อ่าน Published Profile ผ่าน ContentRepository เช่นเดียวกับ public route อื่น

URL ที่ตรวจสอบได้

- Production public: <https://napatdev.com/> ตอบ HTTP 200 แต่ยังเป็น runtime เดิมและ **ไม่ใช่หลักฐาน CMS cutover**
- Production Admin target: <https://napatdev.com/admin/login> ปัจจุบันตอบ HTTP 404 เพราะยังไม่ใช้ CMS runtime; ต้องตรวจสอบซ้ำหลัง cutover
- Preview: <https://napata-git-feat-cms-r-8e1a7a-napat-pamornsuts-projects-14be8929.vercel.app/> deployment ผ่าน แต่ต้องผ่าน Vercel SSO
- Preview Admin: <https://napata-git-feat-cms-r-8e1a7a-napat-pamornsuts-projects-14be8929.vercel.app/admin/login> หลัง authenticated UAT

Runbook สำหรับ Preview/Production

1. ตรวจสอบ target แบบไม่ทำลายข้อมูล

ใช้ secret manager หรือ shell session ที่ไม่บันทึกค่า secret ลง source/log แล้วกำหนด **PORTFOLIO_CMS_SCHEMA** ให้ตรงกับ **DATABASE_URL** query parameter ทุกครั้ง

```
PORTFOLIO_CMS_SCHEMA=portfolio_cms_preview \
DATABASE_URL='postgresql://USER:<redacted>@HOST:5432/DB?schema=portfolio_cms_preview' \
PORTFOLIO_INVENTORY_OUTPUT=artifacts/portfolio-supabase-inventory.json \
npm run cms:inventory
```

Inventory เป็น read-only และควรตรวจสอบ database, current schema, search path, non-system schemas, object names, migration history, auth counts, storage bucket และ policies ก่อนแก้ไขใด ๆ

ตรวจสอบหรือสร้าง dedicated Storage bucket หลัง inventory โดยใช้คำสั่ง guarded นี้:

```
SUPABASE_URL='https://PROJECT_REF.supabase.co' \
SUPABASE_SERVICE_ROLE_KEY=<secret-manager-injected-value> \
PORTFOLIO_STORAGE_BUCKET=portfolio-cms \
node scripts/ensure-storage.mjs
```

ถ้า bucket ยังไม่มี ให้เพิ่ม **PORTFOLIO_STORAGE_CONFIRM=CREATE_PORTFOLIO_CMS_BUCKET** ใน secret-managed session เท่านั้น

2. Backup ก่อน migration หรือ cutover

```
PORTFOLIO_CMS_SCHEMA=portfolio_cms_preview \
DATABASE_URL='postgresql://USER:<redacted>@HOST:5432/DB?schema=portfolio_cms_preview' \
npm run cms:backup
```

Production ต้องมี confirmation exact ผ่าน secret manager เท่านั้น:

```
PORTFOLIO_BACKUP_CONFIRM=BACKUP_PORTFOLIO_PRODUCTION
```

ห้ามใส่ database password, service-role key หรือ confirmation value ลง GitHub comment, source หรือ screenshot

3. Migrate และ import ตามลำดับ

```
PORTFOLIO_CMS_SCHEMA=portfolio_cms_preview \
DATABASE_URL='postgresql://USER:<redacted>@HOST:5432/DB?schema=portfolio_cms_preview' \
npm run cms:migrate

PORTFOLIO_CMS_SCHEMA=portfolio_cms_preview \
DATABASE_URL='postgresql://USER:<redacted>@HOST:5432/DB?schema=portfolio_cms_preview' \
npm run cms:import
```

Importer เป็น idempotent และไม่ reset database; ตรวจสอบจำนวน imported/skipped, slugs, locale fields, order, links และ rendered public pages หลัง import

4. Non-production restore demonstration

Restore จำกัดไว้ที่ **portfolio_cms_dev** หรือ **portfolio_cms_preview** และต้องใช้ไฟล์ได้ **artifacts/backups**:

```
PORTFOLIO_CMS_SCHEMA=portfolio_cms_preview \
DATABASE_URL='postgresql://USER:<redacted>@HOST:5432/DB?schema=portfolio_cms_preview' \
PORTFOLIO_BACKUP_FILE=artifacts/backups/portfolio-portfolio_cms_preview-YYYY-MM-DD.dump \
PORTFOLIO_RESTORE_CONFIRM=RESTORE_PORTFOLIO_CMS_NONPROD \
npm run cms:restore
```

Restore ใช้ `pg_restore --schema --clean --if-exists --single-transaction`; script ปล่อย portfolio_cms_prod

5. Vercel environment checklist

ตั้งค่าแยกตาม target และตรวจชื่อ/target โดยไม่เปิดเผยค่า:

- **CONTENT_STORAGE=database**
- **DATABASE_URL** ชื่อ schema ที่ตรงกับ target
- **BETTER_AUTH_SECRET** ยาวอย่างน้อย 32 ตัวอักษร
- **BETTER_AUTH_URL** เป็น absolute HTTPS URL ของ target และ **BETTER_AUTH_TRUSTED_ORIGINS** เป็น comma-separated HTTPS origins ของ target; production ไม่มี fallback
- **PREVIEW_SIGNING_SECRET** แยกจาก auth secret
- **SUPABASE_URL, SUPABASE_SERVICE_ROLE_KEY, PORTFOLIO_STORAGE_BUCKET**
- **ADMIN_ACTIVATION_TOKEN** ใช้ครั้งเดียวแล้วลบ

ก่อน promote ให้ตรวจ Preview และ Production environment variables ใน Vercel dashboard โดยดูเฉพาะ key/target/updated state ไม่แสดง value

Authenticated UAT ที่ยังต้องทำ

ใช้บัญชี admin จริงบน Preview แล้วตั้งค่าที่ไม่ commit ลง source:

```
CMS_E2E_BASE_URL=https://<protected-preview-host> \
CMS_E2E_ADMIN_EMAIL='<admin-email>' \
CMS_E2E_ADMIN_PASSWORD='<admin-password>' \
CMS_E2E_ALLOW_MUTATIONS=true \
npm run test:e2e
```

ต้องเห็นหลักฐานต่อไปนี้ใน Preview:

1. login และ logout สำเร็จ
2. invalid URL/Markdown ถูกปฏิเสธ
3. Save Draft แล้ว public list/detail/meta/JSON-LD/sitemap/search ยังเป็น Published เดิม
4. Exact Preview แสดงเฉพาะ revision ที่เลือกและมี **noindex**
5. Publish ทำให้ public consumers เปลี่ยนพร้อมกัน
6. rename สร้าง redirect chain ที่ไม่เปิด Draft/Archived
7. Archive เอา item ออกจาก public list/detail โดยไม่ลบ history
8. Restore สร้าง Draft ใหม่และ Preview/Publish ได้
9. media upload/delete obeys reference protection

การยืนยัน destructive action ต้องส่ง JSON { "confirm": true }; request ที่ไม่มีค่านี้ถูกปฏิเสธที่ API

Rollback

- Application: promote deployment ก่อนหน้าใน Vercel หลังตรวจเหตุผลและ target ให้ตรง
- Content: Revision history -> Restore as Draft -> Exact Preview -> Publish
- Database: หยุด rollout, เก็บ backup/inventory, ใช้ forward migration หรือ non-production restore ที่ได้รับอนุมัติ; ห้าม reset shared database
- Storage: ห้ามลบ asset ที่ยังมี Published/Draft reference

Blocker ที่ต้องให้ผู้ดูแลระบบทำต่อ

เพื่อปิด #11-#14 และประกาศ Production readiness ต้องมีทั้งสามอย่างนี้:

1. เปิด authenticated Vercel session ให้ตรวจ protected Preview หรือให้ผู้ดูแลทำ UAT แล้วแนบผลลัพธ์
2. เชื่อม Supabase target ที่อนุมัติ พร้อม connection/service credentials ผ่าน secret manager และมี **pg_dump/pg_restore**
3. ให้ผู้มีสิทธิ์ cutover ตรวจ backup hash, inventory, migration/import result, Vercel env targets และ production smoke ก่อน promote

จนกว่าจะมีหลักฐานข้างต้น สถานะที่ถูกต้องคือ **Implementation/CI/Preview GREEN; Supabase UAT และ Production NOT VERIFIED**

ไฟล์ส่งมอบ

- Markdown ฉบับนี้: **PORTFOLIO_CMS_HANDOVER.md**
- PDF สำหรับส่งต่อ: **PORTFOLIO_CMS_HANDOVER.pdf** — 8 หน้า A4, Sarabun embedded, มีเลขหน้าและภาพ browser local/Production ก่อน cutover; ตรวจแล้วไม่รวม credential หรือ secret value